Who measures what?

Who needs DevSecOps metrics?

- **Developers:** measure effectiveness of features and deployments.
- **Security teams:** monitor compliance, vulnerabilities, evaluate security controls.
- **Operations teams:** ensure system uptime and minimize downtime caused by security incidents.
- **Leadership and executives:** measure value and cost-effectiveness of security initiatives.
- **Architects:** evaluate the impact of security on system design.

DevSecOps metrics provide actionable insights tailored to the needs of different stakeholders. By collecting and analyzing these metrics, organizations can enhance collaboration, ensure continuous improvement, and maintain a robust security posture across all teams.

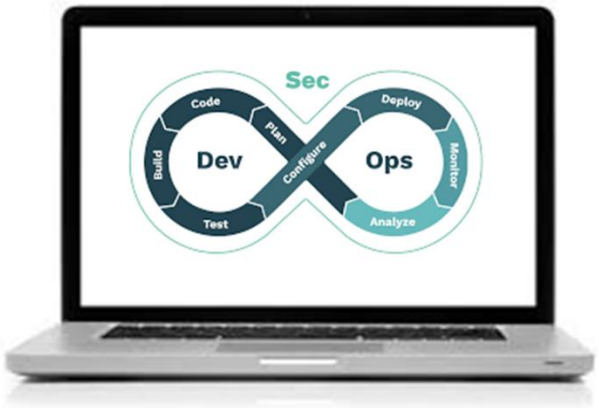


Copyright© 2025 PeopleCert International Ltd.

DevSecOps metrics



Source: https://medium.com/gits-apps-insight/dora-metrics-how-to-measure-software-delivery-performance-e890ec2011c0





DORA Metrics

DevSecOps-specific metrics

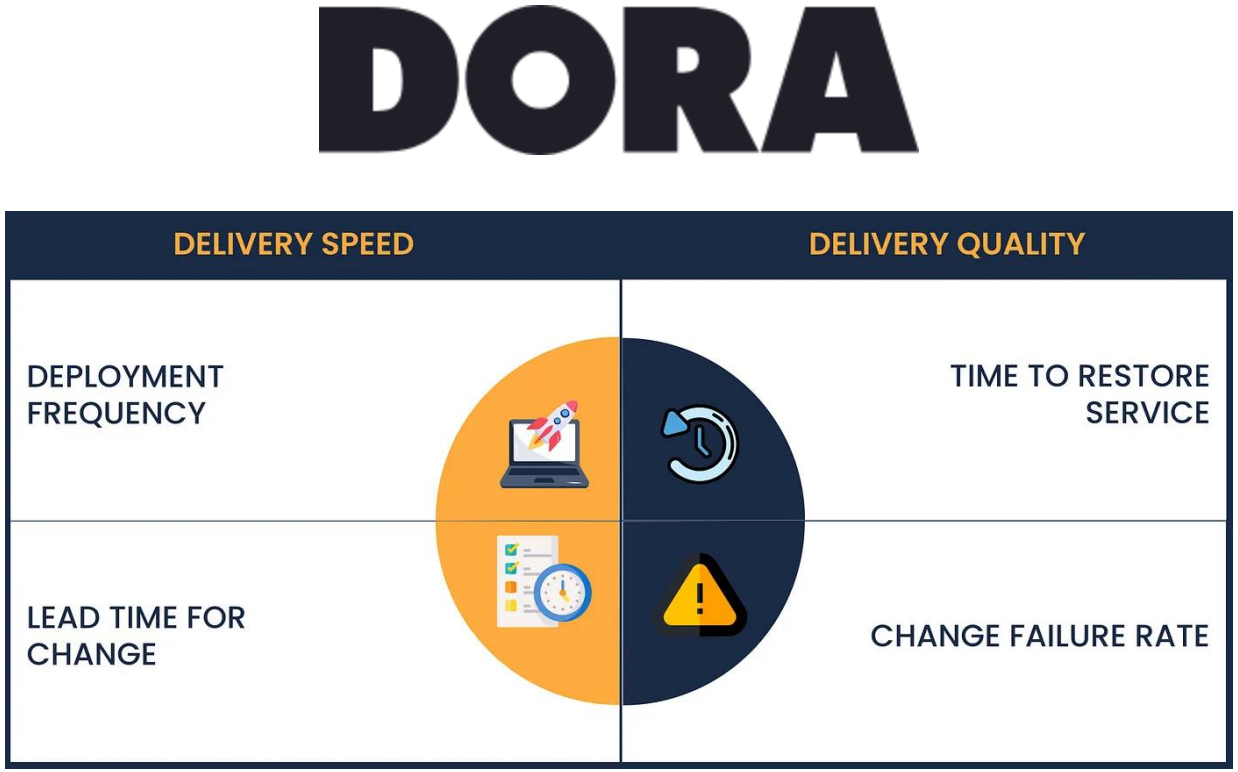
Observability and training metrics

Copyright© 2025 PeopleCert International Ltd.

DORA metrics

DORA metrics are highly valuable in the context of **DevSecOps,** as they help measure the effectiveness of security integration into the development and operations lifecycle:

- **Deployment frequency**
- **Lead time for changes**
- **Mean Time to Restore (MTRS)**
- **Change Failure Rate (CFR).**



Source: https://medium.com/gits-apps-insight/dora-metrics-how-to-measure-software-delivery-performance-e890ec2011c0

Copyright© 2025 PeopleCert International Ltd.

DevSecOps-specific metrics

These metrics provide actionable insights into the effectiveness of security processes, enabling teams to proactively detect vulnerabilities, reduce risks, and build robust, secure systems without compromising delivery speed or agility.

- Time to Remediate (TTR)
- Mean Time to Detect (MTTD)
- number of vulnerabilities detected
- percentage of vulnerabilities fixed
- security test coverage
- security audit pass rate
- false positive rate in security scans
- code review participation rate
- secrets detection rate
- incident response time
- pipeline security tests success rate
- vulnerability recurrence rate
- build failure rate due to security issues
- API security test coverage.



Copyright© 2025 PeopleCert International Ltd.

Observability and training metrics



These metrics enable teams to proactively detect and respond to issues, ensure compliance, and foster a culture of security awareness, ultimately enhancing overall resilience and operational efficiency.

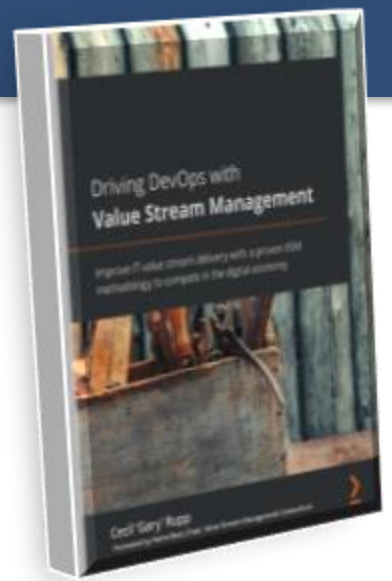
- **observability pillars (logs, traces, metrics)**
- **phishing simulation success rate**
- **security training completion rate**
- **compliance metrics.**

Copyright© 2025 PeopleCert International Ltd.

Organizational metrics and value streams

- Not just pipeline metrics.
- Value stream should be routinely measured and adapted.
- Metrics based on Westrum to ID happiness and contentment:
  - survey
  - interview
  - focus groups.

1. Commit to learn.
2. Choose value stream.
3. Learn about Lean.
4. Map current state.



5. Identify Lean metrics.
6. Map future state:
   - customer demand
   - continuous flows
   - levelling.
7. Create Kaizen plans.
8. Implement Kaizen plans.

Copyright© 2025 PeopleCert International Ltd.